

**Evaluación de la calidad del software mediante métricas, verificación y auditoría –
Caso Medicitas**

Juan Camilo Canasteros González

Especialización en desarrollo de software, UNIMINUTO

Estándares y Métricas de Calidad en el Desarrollo de Software – Semana 2

Docente: Cesar Alfonso Bolado Silva

11 de julio de 2026

Evaluación de la calidad del software mediante métricas, verificación y auditoría –

Caso Medicitas

Introducción

El presente documento evalúa la calidad del sistema MediCitas en su versión 3.2 antes de su liberación, con el objetivo de determinar si cumple con los requisitos técnicos, funcionales y regulatorios establecidos. Para ello, se aplican instrumentos de aseguramiento de calidad como la verificación, la validación y la auditoría, basados en evidencias del escenario como requisitos, incidencias, cambios y resultados de pruebas.

A partir del análisis, se identifican hallazgos críticos que evidencian riesgos en seguridad, desempeño y cumplimiento normativo, lo que permite concluir sobre la viabilidad de su liberación y proponer acciones de mejora.

Contexto del caso

MediCitas es el sistema de información de una red de 12 clínicas ambulatorias que gestiona citas médicas, historias clínicas electrónicas, órdenes médicas, facturación electrónica y notificaciones, e incorporará próximamente telemedicina. La versión 3.2 del sistema, actualmente en preparación, introduce dos cambios mayores: un módulo de videoconsulta y un nuevo esquema de autenticación de único inicio de sesión (SSO). El equipo de desarrollo trabaja bajo Scrum, sin un área de aseguramiento de calidad independiente, y enfrenta una fecha de liberación contractual fija junto con presión comercial por adelantarse a la competencia.

Matriz de verificación y validación

La siguiente matriz distingue, para cada requisito o funcionalidad crítica, si corresponde una actividad de verificación o de validación. La verificación responde a la pregunta: ¿el producto se construyó correctamente conforme a la especificación? Mientras que la validación responde a: ¿el producto satisface la necesidad real del usuario o del negocio?

ID	Requisito / funcionalidad relacionada	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
RF - 014	Autenticación 2FA (obligatoria para roles críticos)	Verificación	Revisión de código + inspección de configuración	Líder técnico	2FA disponible y exigible para roles críticos	Acta de revisión, configuración exportada
RF - 022	Cifrado en reposo de la HCE (AES-256)	Verificación	Revisión técnica de la base de datos y de la librería de cifrado (CR-203)	Administrador de TI / DBA	Todos los campos de datos clínicos cifrados con AES-256 en reposo	Reporte de auditoría técnica de cifrado, configuración de base de datos
RF - 031	Desempeño del módulo de agendamiento (100 usuarios concurrentes)	Validación	Prueba de carga y estrés	Equipo de pruebas	Tiempo de respuesta menor a 2 segundos con 100 usuarios concurrentes	Informe de prueba de carga con métricas de tiempo de respuesta
RF - 045	Log de auditoría inmutable (lectura y escritura de HCE)	Verificación	Revisión de código y prueba funcional de trazabilidad	Desarrollador asignado / Líder técnico	Todo acceso de lectura y escritura a la HCE queda registrado de forma inmutable	Extracto de logs de auditoría con eventos de lectura y escritura
RF - 052	Cumplimiento PCI-DSS en pagos (no registrar tarjeta completa)	Verificación	Auditoría de cumplimiento PCI-DSS y revisión de logs de la pasarela	Oficial de protección de datos / auditor externo	Ningún log contiene el número completo de la tarjeta; controles PCI-DSS satisfechos	Informe de auditoría PCI-DSS, muestra de logs enmascarados
RF - 060	Cifrado de extremo a extremo del canal de video (telemedicina)	Verificación	Revisión de configuración de red y prueba técnica de cifrado del canal	Administrador de TI / Dev 4	El canal de video-consulta se transmite exclusivamente cifrado (sin caída a HTTP)	Reporte técnico de prueba de cifrado de canal, configuración de servidor
RF - 061	Control de acceso basado en roles	Verificación	Revisión de configuración de permisos y roles en el sistema	Líder técnico	Cada rol tiene acceso únicamente a las funcionalidades autorizadas	Matriz de roles y permisos, evidencia de configuración

RF – 062	Usabilidad del módulo de agendamiento	Validación	Pruebas con usuarios finales (UAT)	Equipo de QA / Usuarios	El 90% de usuarios completa tareas sin errores en el primer intento	Resultados de pruebas UAT, encuestas de satisfacción
RF - 063	Disponibilidad del sistema de historia clínica electrónica	Validación	Monitoreo de disponibilidad + prueba de continuidad operativa	Administrador de TI / Equipo de QA	El sistema mantiene una disponibilidad mínima del 99.9% mensual	Reporte de monitoreo, métricas de disponibilidad
RF - 064	Rapidez en el envío de notificaciones vía SMS	Validación	Prueba de rendimiento y latencia en el envío de SMS mediante la pasarela	Equipo de QA / Administrador de TI	El 95% de los mensajes SMS se entregan en un tiempo ≤ 5 segundos desde su generación	Reporte de pruebas de latencia, logs de envío y confirmación de entrega

Actividades de verificación y validación

Con base en los requisitos y funcionalidades identificadas en la matriz, se definen las siguientes actividades de verificación y validación aplicables al escenario:

Actividades de Verificación (revisiones e inspecciones):

Las actividades de verificación están orientadas a asegurar que el sistema ha sido construido correctamente conforme a las especificaciones técnicas y normativas definidas.

- Revisión de código fuente e inspección de la configuración del sistema para validar la correcta implementación del mecanismo de autenticación en roles críticos.
- Revisión técnica de la base de datos y de las librerías de cifrado utilizadas, con el fin de garantizar que los datos clínicos se encuentren protegidos mediante el estándar AES-256.
- Inspección del código y validación de la configuración del sistema de auditoría para asegurar la inmutabilidad y trazabilidad de los logs de acceso a la historia clínica electrónica.

- Auditoría de cumplimiento de la normativa PCI-DSS, incluyendo la revisión de logs de la pasarela de pagos para verificar que no se almacenen datos sensibles completos.
- Revisión de la configuración de red y de los protocolos de seguridad implementados para garantizar el cifrado de extremo a extremo en el canal de telemedicina.
- Inspección de la configuración de control de acceso basado en roles (RBAC), verificando que los permisos asignados correspondan a las responsabilidades de cada tipo de usuario.

Actividades de Validación (pruebas orientadas al usuario):

Las actividades de validación buscan comprobar que el sistema satisface las necesidades reales del usuario y cumple con los criterios de desempeño, usabilidad y operación en condiciones reales.

- Ejecución de pruebas de carga y estrés sobre el módulo de agendamiento, simulando hasta 100 usuarios concurrentes para evaluar tiempos de respuesta y estabilidad.
- Realización de pruebas de usabilidad (UAT) con usuarios finales, con el objetivo de verificar la facilidad de uso del sistema y la correcta ejecución de tareas sin errores.
- Monitoreo de la disponibilidad del sistema de historia clínica electrónica, junto con pruebas de continuidad operativa para garantizar el cumplimiento del nivel de servicio establecido.
- Ejecución de pruebas de rendimiento en el envío de notificaciones vía SMS, midiendo la latencia desde la generación del mensaje hasta su entrega al usuario final.
- Validación del funcionamiento del sistema en escenarios reales de operación, asegurando que los servicios críticos (agendamiento, notificaciones, acceso a información clínica) respondan de manera eficiente y confiable.

Lista de control de revisiones técnicas

El siguiente checklist evalúa, con base en las evidencias del escenario, el cumplimiento de catorce criterios técnicos y regulatorios mínimos antes de la liberación de la versión 3.2.

N.º	Ítem de revision	Cumple	Observaciones / Evidencia
1	El código fuente cumple con los estándares de codificación definidos por el equipo.	N.A.	El escenario no documenta evidencia de estándares de codificación ni de su verificación.
2	Existe trazabilidad entre los requisitos y los casos de prueba.	No	RF-031 no fue probado bajo carga y RF-052 está pendiente de verificación
3	Todos los cambios fueron documentados y aprobados antes de su despliegue a producción.	No	CR-202 y CR-205 fueron desplegados sin revisión ni aprobación registrada.
4	Los mecanismos de autenticación y autorización protegen adecuadamente los recursos críticos.	No	INC-101: se accedió sin autorización a una historia clínica
5	La información sensible (datos clínicos, financieros) se almacena y transmite cifrada.	No	INC-104 no se enmascaran los datos de pago
6	Existen registros de auditoría (logs) para accesos y modificaciones a información crítica.	No	INC-105: Solo hay logs de modificaciones, no de consulta
7	Se ejecutaron pruebas de seguridad (pentesting) antes de la liberación.	No	La prueba del módulo de historia clínica no fue ejecutada por falta de tiempo en el calendario
8	Se ejecutaron pruebas de carga/rendimiento sobre los módulos críticos.	No	La prueba del modulo de telemedicina no fue ejecutada ya que no hay ambiente de

			pruebas de carga disponible
9	El manejo de datos personales cumple con la Ley 1581 de 2012 y su reglamentación.	No	Hubo acceso indebido al sistema (INC-101) y se expusieron datos sensibles de pago (INC-104)
10	El manejo de la historia clínica cumple con la Resolución 1995 de 1999.	No	Solo se registran escrituras en el log de historia clínica (INC-104) y hubo acceso indebido (INC-101)
11	El módulo de telemedicina cumple con las disposiciones de la Resolución 2654 de 2019.	No	La transmisión de la llamada quedo en HTTP (INC-103)
12	Existen alertas automáticas ante fallos de procesos críticos (p. ej., el batch de facturación).	No	Hubo 3 fallos no alertados en el proceso batch nocturno (INC-106)
13	La documentación técnica y de usuario está actualizada para la versión a liberar.	N.A.	No hay evidencia de que la documentación este actualizada
14	Los riesgos técnicos y regulatorios identificados fueron mitigados antes de la liberación.	No	Hubo un despliegue de cambios sin haber sido aprobados
15	Las notificaciones SMS se envían dentro de los tiempos establecidos.	N.A.	Hubo un cambio de proveedor exitoso, pero no se evidencia si fue testeado cumpliendo los tiempos de recepción de mensajes
16	El sistema cumple con niveles adecuados de	N.A.	No se evidencia documentación acerca de la

	disponibilidad ($\geq$ 99.9%).		disponibilidad del servicio en el entorno de pruebas
--	---------------------------------	--	--

De los dieciséis ítems evaluados, doce presentan incumplimiento ("No") y cuatro no cuentan con evidencia suficiente en el escenario ("N.A."). Ningún ítem relacionado con seguridad, disponibilidad, cifrado, trazabilidad o cumplimiento regulatorio se cumple plenamente, lo cual constituye una señal de alerta significativa para la liberación.

Formato de auditoria

Datos generales

Campo	Contenido
Objetivo de la auditoría	Evaluar el cumplimiento de los requisitos de seguridad, desempeño y regulatorios de la versión 3.2 de MediCitas antes de su liberación contractual
Alcance	Módulos de autenticación, historia clínica electrónica, telemedicina, facturación e integración con la pasarela de pagos, considerando los cambios introducidos en la versión 3.2
Criterios de auditoría (normas/estándares de referencia)	ISO/IEC 25010, Ley 1581 de 2012 y Decreto 1377 de 2013, Resolución 1995 de 1999, Resolución 2654 de 2019, Resolución 3100 de 2019, estándar PCI-DSS
Equipo auditor	Juan Camilo Canasteros González
Fecha de ejecución	12 de julio de 2026
Evidencias a recolectar	Bitácora de incidencias, lista de control de cambios, resultados de pruebas preliminares y especificación de requisitos del sistema

Hallazgos

N.º	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Acceso indebido a historias clínicas de pacientes mediante la manipulación del URL	Resolución 1995 de 1999 (Ministerio de Salud) Ley 1581 de 2012 y Decreto 1377 de 2013	INC-101	Alta	Implementar validación de autorización a nivel de servidor para cada solicitud
2	El modulo de telemedicina no cifro el canal de video de extremo a extremo	Ley 1581 de 2012 y Decreto 1377 de 2013	INC-103	Alta	Reforzar el control de configuraciones en la transmisión sobre HTTPS
3	Cuenta administrativa "admin_ti" compartida entre 4 personas, con contraseñas que no expiran	ISO/IEC 25010 - Seguridad	INC-102	Alta	Asignar cuentas individuales y exigir una política de expiración de contraseñas
4	Los logs de los datos de pago (sensibles) no se enmascararon	Ley 1581 de 2012 y Decreto 1377 de 2013	INC-104	Alta	Enmascarar o eliminar los datos de tarjeta en los logs
5	Solo hubo registro de modificaciones en las historias clínicas	Resolución 1995 de 1999 (Ministerio de Salud)	INC-105	Alta	Ampliar el mecanismo de auditoría para registrar también los accesos de lectura

Aplicación del Estandar ISO/IEC 25010 al caso

Se seleccionó el estándar ISO/IEC 25010 como referencia para evaluar la nueva versión de MediCitas, dado que cubre de forma integral las características más críticas del escenario: seguridad, fiabilidad, eficiencia de desempeño y compatibilidad.

- Seguridad: Se identifican vulnerabilidades asociadas al acceso indebido a la información mediante una URL, así como la ausencia de mecanismos adecuados de enmascaramiento de datos sensibles en los logs durante el procesamiento de pagos, lo cual representa un riesgo de exposición de información confidencial.
- Fiabilidad: El sistema presenta múltiples fallos y se evidencian cambios recientes que no han sido sometidos a pruebas completas, lo que afecta negativamente la estabilidad y consistencia del sistema.
- Eficiencia del desempeño: No fue posible medir completamente el rendimiento del sistema, debido a que las pruebas de carga del módulo de agendamiento con 100 usuarios concurrentes no se ejecutaron de manera satisfactoria
- Compatibilidad: El módulo de facturación presenta fallas intermitentes que impactan el funcionamiento del sistema

Métricas de calidad

Con base en el modelo ISO/IEC 25010 y las características que definen la calidad para la liberación de la nueva versión, se definieron las siguientes métricas:

Métrica	Forma de medición	Criterio de aceptación	Aplicación al caso
Cobertura de pruebas	(Casos ejecutados / Casos planificados) × 100	≥ 95%	No se alcanzó completamente, ya que pruebas críticas como carga concurrente no fueron ejecutadas. Cobertura parcial
Tasa de éxito de pruebas	(Casos aprobados / Casos ejecutados) × 100	≥ 90%	No se cumple totalmente debido a fallos detectados en seguridad y

			facturación. Hay pruebas fallidas o incompletas
Densidad de defectos	Número de defectos / funcionalidades probadas	≤ 0.5 defectos por funcionalidad	Se identificaron múltiples problemas en la seguridad, facturación y cambios sin probar, lo que indica una densidad de defectos mayor a la esperada.
Tiempo de respuesta del sistema	Tiempo promedio de respuesta en segundos	$\leq 2-3$ segundos	No se pudo validar correctamente porque no se realizaron pruebas de carga con 100 usuarios concurrentes. Métrica no comprobada.
Disponibilidad del sistema	$(\text{Tiempo activo} / \text{tiempo total}) \times 100$	$\geq 99.9\%$	La disponibilidad es incierta debido a fallas intermitentes en el módulo de facturación. Riesgo de no cumplimiento.

Conclusión general

La evidencia recopilada indica que la versión 3.2 de MediCitas no se encuentra en condiciones de liberarse en la fecha contractual sin exponer a la organización a riesgos de seguridad, regulatorios y reputacionales significativos. Los cinco hallazgos de auditoría son de severidad alta o media-alta y afectan directamente el cumplimiento de la Resolución 1995 de 1999, la Resolución 2654 de 2019 y el estándar PCI-DSS, además de dejar sin corregir una vulnerabilidad de control de acceso a historias clínicas (INC-101) y una cuenta administrativa compartida sin controles (INC-102).

Se recomienda solicitar un cambio en la fecha de liberación, con el fin de completar las pruebas pendientes, validar las nuevas funcionalidades incorporadas y fortalecer el proceso

de gestión y aprobación de cambios. Esto permitirá garantizar que la nueva versión sea desplegada de manera controlada, segura y sin fallas críticas.

Recomendaciones priorizadas

- **Prioridad crítica:** Corregir el control de acceso a la historia clínica (INC101), enmascarar los datos de tarjeta en los logs de pago (INC104) y completar la verificación del cifrado de la HCE (RF-022), por su impacto directo en la confidencialidad de datos regulados.
- **Prioridad alta:** Restaurar y confirmar el cifrado de extremo a extremo del canal de video (INC103) y ejecutar la validación regulatoria de telemedicina frente a la Resolución 2654 y 3100 de 2019. Asimismo, eliminar la cuenta administrativa compartida (INC102) y formalizar la revisión y aprobación obligatoria de todo cambio antes de su despliegue (CR202, CR205).
- **Prioridad media:** Ejecutar las pruebas de carga pendientes del módulo de agendamiento (RF-031/INC107) y las pruebas de seguridad (pentesting) de la HCE. Adicionalmente, implementar alertas automáticas para el proceso batch de facturación (INC106) y ampliar el log de auditoría para registrar también los accesos de lectura a la HCE (RF-045/INC105).

Referencias

Bolado Silva, C. A. (2026). *Archivo de apoyo Semana 2: Aseguramiento de la calidad del software [Documento de curso]*.

Congreso de la República de Colombia. (2012). *Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*.

International Organization for Standardization. (2011). *ISO/IEC 25010: Systems and software engineering — Systems and software quality requirements and evaluation (SQuaRE)*.

Ministerio de Salud y Protección Social de Colombia. (1999). *Resolución 1995 de 1999, por la cual se establecen normas para el manejo de la historia clínica*.

Ministerio de Salud y Protección Social de Colombia. (2019). *Resolución 2654 de 2019, por la cual se establecen disposiciones para la telesalud*.

Ministerio de Salud y Protección Social de Colombia. (2019). *Resolución 3100 de 2019, por la cual se definen los procedimientos y condiciones de habilitación de servicios de salud*.

Presidencia de la República de Colombia. (2013). *Decreto 1377 de 2013, por el cual se reglamenta parcialmente la Ley 1581 de 2012*.

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard (PCI-DSS), versión 4.0*.

Portal ISO 25000. (s.f.). *ISO/IEC 25010*. Alarcos Quality Products.

<https://iso25000.com/index.php/normas-iso-25000/iso-25010>